

PENETRATION TESTING REPORT

Mediroza General Hospital

Client	Mediroza General Hospital
Target	https://medirozahospital.com
IP Address	199.188.201.16
Assessment Type	Black-Box Penetration Test
Tester	Blessing Princess Augustine
Batch / Week	B083 — Week 4
Organisation	NetworkWalks Academy
Date	01 October 2026
Duration	5 Days
Classification	CONFIDENTIAL — AUTHORISED PERSONNEL ONLY

WRITTEN PERMISSION: GRANTED

□

01. EXECUTIVE SUMMARY

This report presents the findings of a black-box penetration test conducted against the web infrastructure of Mediroza General Hospital (https://medirozahospital.com). The assessment was authorised in writing by the client and carried out over a five-day period as part of NetworkWalks Academy Batch B083, Week 4. The tester operated with no prior knowledge of the application, simulating a real-world external attacker.

The engagement identified two critical-severity vulnerabilities, both of which were successfully exploited. The first was a SQL injection flaw in the patient portal login form, which allowed complete authentication bypass and unauthorised access to three confidential patient pathology lab reports. The second was an exposed MySQL database backup file stored in a publicly accessible directory with no authentication required. This file contained the full salary records, national ID numbers and personal contact details of 30 hospital staff, as well as the complete shareholder register.

In addition to these critical findings, the assessment identified directory indexing enabled across multiple sensitive directories, weak PDF encryption passwords that were cracked within seconds using a common wordlist, an exposed web server control panel, a cross-site scripting vulnerability in the webmail component, and five missing HTTP security headers across all server responses.

The overall risk to Mediroza General Hospital is rated Critical. Patient confidentiality has been compromised, staff personal data has been exposed, and corporate financial information is publicly accessible. Immediate remediation is required.

□

02. SCOPE AND METHODOLOGY

Scope

Target Domain	https://medirozahospital.com
Target IP	199.188.201.16
Scope Limit	Target domain only — no social engineering, no denial of service
Type	Black-box penetration test
Authorisation	Written permission granted by the client via

Approach

The assessment followed a structured penetration testing methodology, progressing through five phases: passive reconnaissance, active scanning, vulnerability identification, exploitation, and post-exploitation analysis.

- Phase 1 — Passive Reconnaissance: HTTP header fingerprinting (curl -i), HTML source review, robots.txt enumeration
- Phase 2 — Active Scanning: Nikto web vulnerability scan, directory indexing enumeration
- Phase 3 — Vulnerability Identification: SQL injection testing, authentication behaviour analysis, input validation assessment
- Phase 4 — Exploitation: SQL injection auth bypass, PDF password cracking, unauthenticated file retrieval
- Phase 5 — Post-Exploitation: Database backup analysis, sensitive data extraction

Tools Used

Tool	Purpose
curl	HTTP header and HTML source analysis
Nikto v2.6.0	Automated web vulnerability scanning
pdfcrack	PDF password cracking against rockyou.txt wordlist
pdf2john	PDF hash extraction
wget	Unauthenticated file retrieval from exposed directory
Firefox	Manual browser-based testing and verification
rockyou.txt	Common password wordlist (14 million entries)

Limitations

Nessus Essentials was installed on Kali Linux during the assessment but encountered networking and configuration issues that prevented it from completing a scan. The assessment proceeded successfully using alternative tools. OS fingerprinting via Nmap returned unreliable results due to insufficient open/closed port pairs on the target.

□

03. FINDINGS AND PROOF OF EXPLOITATION

Reconnaissance

HTTP Header Analysis

Running curl -i against the homepage fingerprinted the server stack and revealed two login endpoints embedded directly in the HTML source.

```
curl -i https://medirozahospital.com
```

```
Session Actions Edit View Help
kali@kali: ~
❯ curl -i https://medirozahospital.com
HTTP/2 200
content-type: text/html
last-modified: Fri, 04 Sep 2020 02:03:12 GMT
accept-ranges: bytes
content-length: 5465
date: Thu, 01 Oct 2020 10:32:55 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<meta name="author" content="Mediroza IT Department">
<meta name="description" content="Mediroza General Hospital - trusted healthcare, modern facilities and specialist doctors serving the community.">
<meta name="generator" content="Mediroza CMS 1.4.2">
<title>Mediroza General Hospital | Compassionate Care, Advanced Medicine</title>
<link rel="stylesheet" href="/styles.css">
</head>
<body>


Emergency: +27 11 555 0100
Open 24/7
Staff Login
Find Us



Home







Mediroza



Home
About
Doctors
Contact
Patient Portal



## Staff Login



Internal staff access only.


```

Figure 1 — curl -i: LiteSpeed server; Mediroza CMS 1.4.2, /staff/login.php and /patient/login.php discovered in HTML source

Login Page Inspection

Both login pages were inspected for form structure and security controls. Neither form contained a CSRF token or rate-limiting mechanism.

```
curl -i https://medirozahospital.com/staff/login.php
curl -i https://medirozahospital.com/patient/login.php
```

```
$ curl -i https://medirozahospital.com/staff/login.php
curl -i https://medirozahospital.com/patient/login.php
HTTP/2 200
x-powered-by: PHP/8.2.33
content-type: text/html; charset=UTF-8
content-length: 1895
date: Thu, 01 Oct 2020 10:39:49 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<meta name="generator" content="Mediroza CMS 1.4.2">
<title>Staff Login | Mediroza General Hospital</title>
<link rel="stylesheet" href="/styles.css">
</head>
<body>


Emergency: +27 11 555 0100
Open 24/7
Back to Site



Home







Mediroza



Home
About
Doctors
Contact
Patient Portal



## Staff Login



Internal staff access only.


```

Figure 2 — curl -i on both login pages: PHP/8.2.33 confirmed, no CSRF token, POST fields: username and password

Nikto Vulnerability Scan

Nikto identified directory indexing on three sensitive paths, five missing security headers, an XSS-vulnerable webmail component, and an exposed server control panel.

```
nikto -h https://medirozahospital.com
```


Finding 1 — SQL Injection Authentication Bypass (M1)

Severity: CRITICAL

CWE	CWE-89 — Improper Neutralisation of Special Elements in an SQL Command
Location	https://medirozahospital.com/patient/login.php
Impact	Full authentication bypass — unauthorised access to all patient lab reports

Description

The patient portal login form at /patient/login.php was found to be vulnerable to SQL injection. The application passes user-supplied input directly into SQL queries without sanitisation or parameterised queries. By injecting a SQL comment operator into the username field, the password condition in the query is commented out entirely, allowing login without any valid credentials.

Payload Used

Username: admin' --
Password: admin' --

The -- sequence is a SQL comment operator. When injected, the server executes the query as: SELECT * FROM users WHERE username='admin' -- ' AND password='...' — the password check never runs, and the query returns a valid user.

Proof of Exploitation

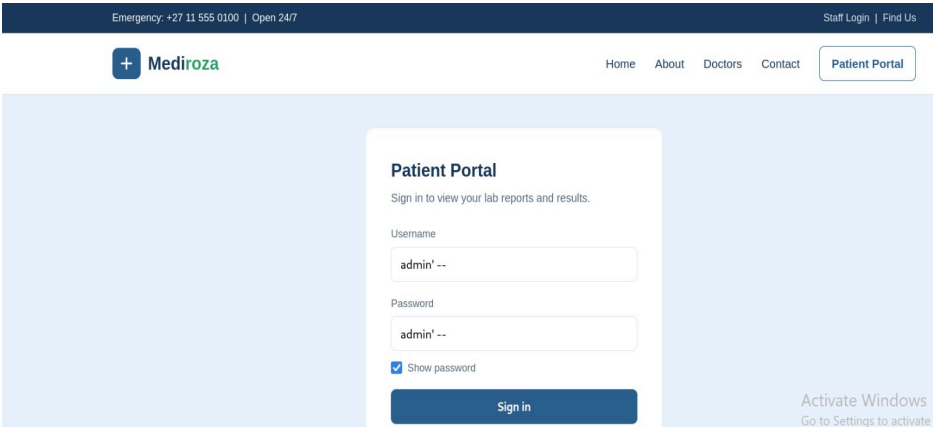


Figure 6 — SQL injection payload entered in the Patient Portal login form

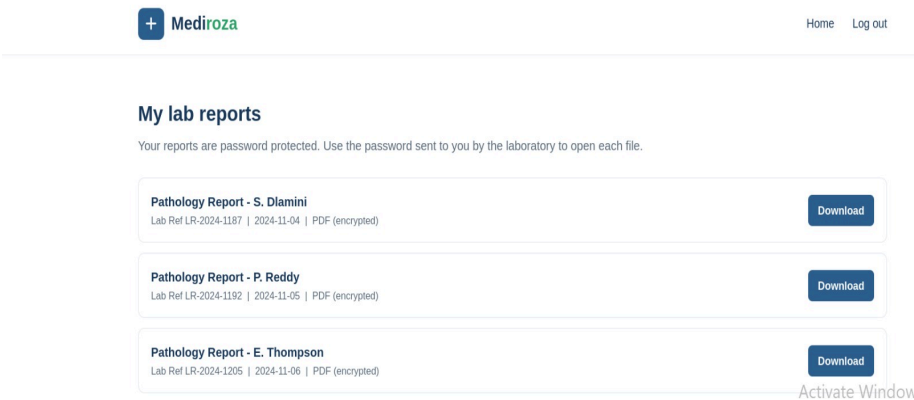


Figure 7 — Successful access: patient portal dashboard showing 3 confidential lab reports after SQL injection bypass

The three lab reports retrieved from the portal:

File	Patient	Lab Ref	Date
patient_report_1.pdf	Sipho Dlamini	LR-2024-1187	2024-11-04

patient_report_2.pdf	Priya Reddy	LR-2024-1192	2024-11-05
patient_report_3.pdf	Emily Thompson	LR-2024-1205	2024-11-06

□

Finding 2 — Weak PDF Encryption Passwords (M2)

Severity: HIGH

CWE	CWE-521 — Weak Password Requirements
Encryption	PDF Standard V2.3, 128-bit RC4
Impact	All 3 encrypted patient pathology reports decrypted within seconds

Description

All three downloaded patient lab reports were encrypted with user passwords. Despite the encryption, all three passwords were recovered in seconds using pdfrack against the rockyou.txt common password wordlist. The passwords used were among the most widely known in the world, making the encryption effectively worthless as a security control.

Proof of Exploitation

```
pdfrack -f patient_report_1.pdf -w /usr/share/wordlists/rockyou.txt
pdfrack -f patient_report_2.pdf -w /usr/share/wordlists/rockyou.txt
pdfrack -f patient_report_3.pdf -w /usr/share/wordlists/rockyou.txt
```

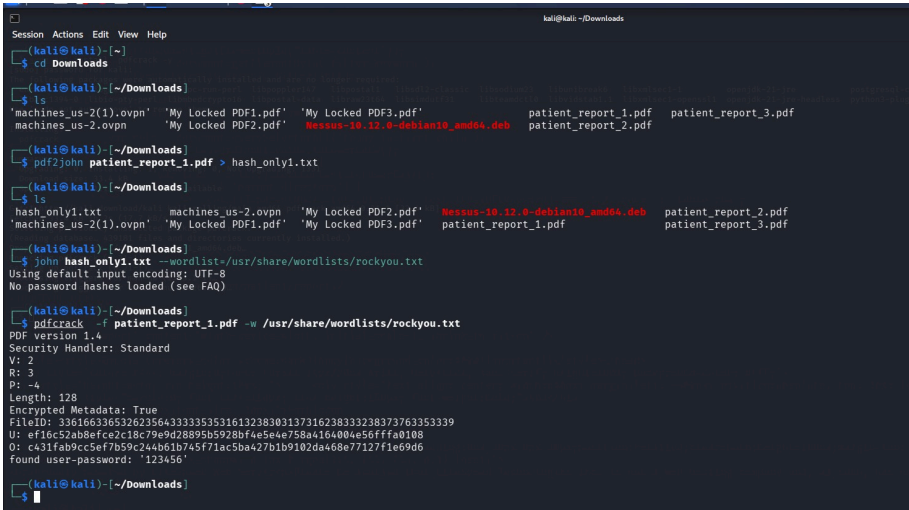


Figure 8 — pdfrack: patient_report_1.pdf password found: '123456'

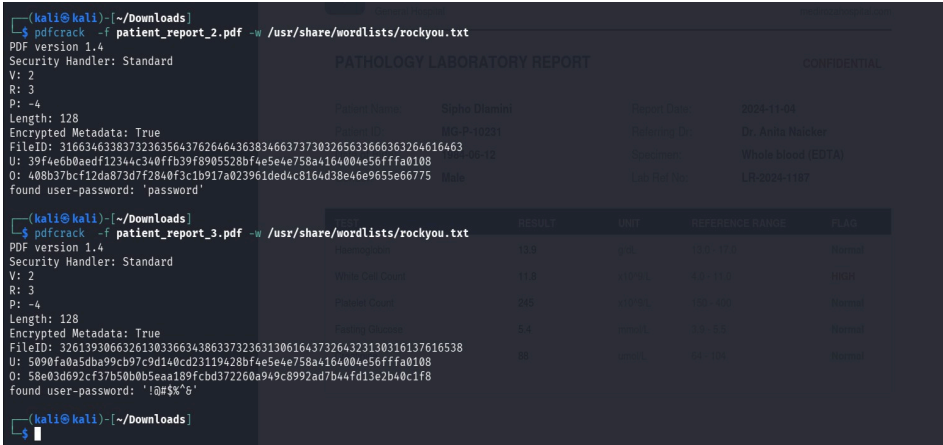


Figure 9 — pdfrack: patient_report_2.pdf: 'password', patient_report_3.pdf: '!@#%&^&'

--	--	--	--	--

File	Patient	Password	Severity Assessment
patient_report_1.pdf	Sipho Dlamini	123456	Most common password globally
patient_report_2.pdf	Priya Reddy	password	Second most common password globally
patient_report_3.pdf	Emily Thompson	!@#\$%^&	Predictable keyboard sequence, in rockyou.txt

Decrypted Report Contents


Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT
CONFIDENTIAL

Patient Name: **Sipho Dlamini**
Patient ID: **MG-P-10231**
Date of Birth: **1984-06-12**
Gender: **Male**

Report Date: **2024-11-04**
Referring Dr: **Dr. Anita Naicker**
Specimen: **Whole blood (EDTA)**
Lab Ref No: **LR-2024-1187**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Figure 10 — patient_report_1.pdf decrypted: Sipho Dlamini — Pathology Lab Report (LR-2024-1187)


Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT
CONFIDENTIAL

Patient Name: **Priya Reddy**
Patient ID: **MG-P-10244**
Date of Birth: **1991-02-28**
Gender: **Female**

Report Date: **2024-11-05**
Referring Dr: **Dr. Johan van der Merwe**
Specimen: **Serum**
Lab Ref No: **LR-2024-1192**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Figure 11 — patient_report_2.pdf decrypted: Priya Reddy — Pathology Lab Report (LR-2024-1192)


Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT
CONFIDENTIAL

Patient Name: **Emily Thompson**
Patient ID: **MG-P-10258**
Date of Birth: **1978-09-03**
Gender: **Female**

Report Date: **2024-11-06**
Referring Dr: **Dr. Ahmed Kara**
Specimen: **Serum**
Lab Ref No: **LR-2024-1205**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Figure 12 — patient_report_3.pdf decrypted: Emily Thompson — Pathology Lab Report (LR-2024-1205)

□

Finding 3 — Unauthenticated Database Backup Exposure (M3)

Severity: CRITICAL

CWE	CWE-552 — Files or Directories Accessible to External Parties
Location	https://medirozahospital.com/old/mediroza_db_backup_2019.sql
Impact	Full database exposed — 30 staff records with national IDs, salaries, and complete shareholder register

Description

A complete MySQL database backup was discovered in the publicly accessible /old/ directory. The file required no authentication to access and could be downloaded directly via a browser or command line. The discovery followed the reconnaissance chain: Nikto flagged /old/ as having directory indexing enabled, robots.txt confirmed the path existed and was considered sensitive, and browsing directly to the directory revealed the backup file. The database itself contained an internal WARNING comment acknowledging that it held confidential staff and shareholder records.

Proof of Exploitation

curl https://medirozahospital.com/old/

```
(kali@kali)~$ curl https://medirozahospital.com/old/
<!DOCTYPE html><html><head><meta http-equiv="Content-type" content="text/html; charset=UTF-8" /><meta name="viewport" content="width=device-width, initial-sc
" href="/_autoindex/assets/css/autoindex.css" /><script src="/_autoindex/assets/js/tablesort.js"></script><script src="/_autoindex/assets/js/tablesort.number
ld/</title><style>@media (prefers-color-scheme:dark){body{background-color:#000!important}}</style></head><body><div class="content"><h1 style="color: #555;"
<div id="table-list"><table id="table-content"><thead class="t-header"><tr><th class="colname" aria-sort="ascending"><a class="name" href="?ND" onclick="ret
ss="colname" data-sort-method="number"><a href="?MA" onclick="return false">Last Modified</a></th><th class="colname" data-sort-method="number"><a href="?S
</a></th></tr></thead>
<tr data-sort-method="none"><td><a href="/">Parent Directory</a></td><td><td><t
<tr><td data-sort="mediroza_db_backup_2019.sql"><a href="/old/mediroza_db_backup_2019.sql"></td><td data-sort="1788487331">2026-09-04 02:02</td><td data-sort="6346">7k</td></tr>
</table></div>
<address>Proudly Served by LiteSpeed Web Server at medirozahospital.com Port 443</address></div><script>new Tablesort(document.getElementById("table-content"
```

Figure 13 — curl /old/: directory listing confirms mediroza_db_backup_2019.sql is publicly accessible

wget https://medirozahospital.com/old/mediroza_db_backup_2019.sql

```
(kali@kali)~/Downloads$ wget https://medirozahospital.com/old/mediroza_db_backup_2019.sql
--2026-10-01 15:45:46-- https://medirozahospital.com/old/mediroza_db_backup_2019.sql
Resolving medirozahospital.com (medirozahospital.com) ... 199.188.201.16
Connecting to medirozahospital.com (medirozahospital.com)|199.188.201.16|:443 ... connected.
HTTP request sent, awaiting response ... 200 OK
Length: 6346 (6.2K) [text/x-sql]
Saving to: 'mediroza_db_backup_2019.sql'

mediroza_db_backup_2019.sql      100%[=====]
2026-10-01 15:45:47 (148 MB/s) - 'mediroza_db_backup_2019.sql' saved [6346/6346]
```

Figure 14 — wget: HTTP 200 OK, file downloaded at 148 MB/s — zero credentials required

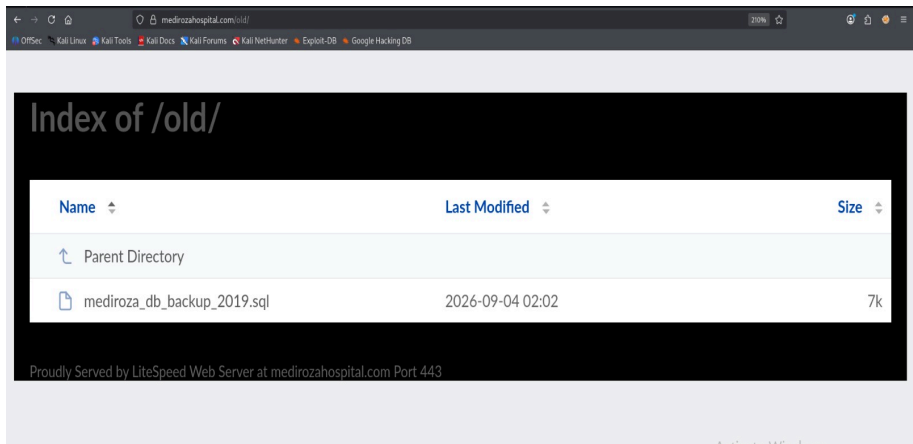


Figure 15 — Browser confirms direct URL access to Index of /old/ with no authentication prompt



Figure 16 — Database backup: full staff table exposing 30 employee records including names, job titles, national IDs and monthly salaries

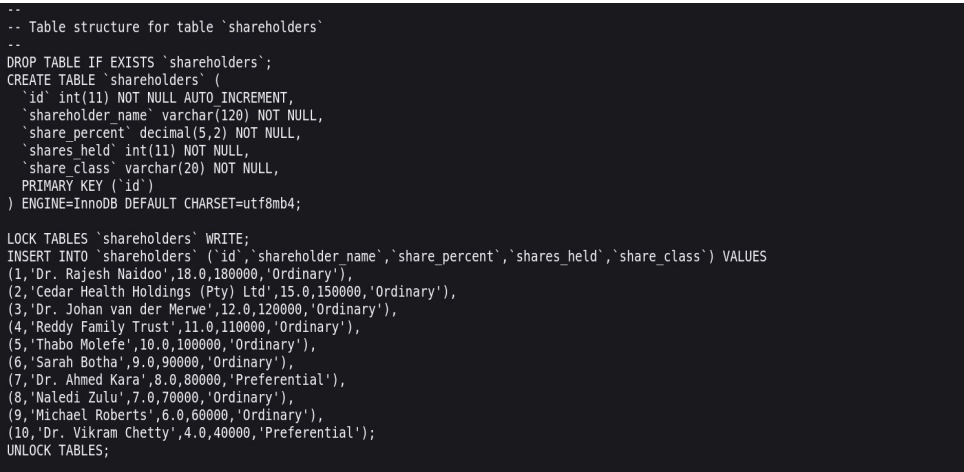


Figure 17 — Database backup: full shareholders table exposing names, share percentages, shares held and share class for all 10 shareholders

□

Additional Findings

Finding	Location	Severity	Description
Directory Indexing	/patient/, /staff/, /old/	High	Full directory contents publicly browsable without authentication
Exposed Control Panel	/securecontrolpanel/	High	Web server control panel

			URL publicly accessible
IlohaMail XSS	/webmail/blank.html	Medium	IlohaMail 0.8.10 contains a known cross-site scripting vulnerability
Missing Content-Security-Policy	/	Medium	Increases risk of XSS and data injection attacks
Missing Strict-Transport-Security	/	Medium	HTTPS not enforced at the response header level
Missing Referrer-Policy	/	Medium	Referrer data leaked to third-party destinations
Missing Permissions-Policy	/	Medium	Browser feature access unrestricted
Missing X-Content-Type-Options	/	Medium	MIME-type sniffing attacks possible
robots.txt Disclosure	/robots.txt	Low	Sensitive directory paths listed publicly

□

04. RISK RATING

Each vulnerability is rated on a four-point scale: Critical, High, Medium, or Low, based on the ease of exploitation, the impact of a successful attack, and the sensitivity of the data or systems affected.

ID	Finding	Rating	Justification
F1	SQL Injection — Patient Portal	Critical	No authentication required. Single payload grants full access to confidential patient medical data.
F2	Database Backup Exposure	Critical	No exploitation skill needed. Public URL downloads full DB with national IDs, salaries and shareholder data.
F3	Directory Indexing (/patient/, /staff/, /old/)	High	Application structure and sensitive files fully exposed without authentication.
F4	Weak PDF Encryption Passwords	High	All three passwords cracked in seconds. Encryption provides no real protection.
F5	Exposed Server Control Panel	High	Control panel URL publicly accessible, increasing attack surface and information exposure.
F6	IlohaMail XSS	Medium	Known CVE in webmail component. Could allow script injection against users of the webmail service.
F7	5 Missing Security Headers	Medium	Absence of CSP, HSTS, Referrer-Policy, Permissions-Policy and X-Content-Type-Options raises XSS, clickjacking and MITM risk.
F8	robots.txt Information Disclosure	Low	Low direct impact but aids attacker reconnaissance by mapping sensitive



05. RECOMMENDATIONS AND REMEDIATION

The following actionable remediation steps are recommended for each identified vulnerability, listed in order of priority.

F1 — SQL Injection (Critical)

The root cause is unsanitised user input being concatenated directly into SQL queries. All database interactions must be rewritten to use parameterised queries or prepared statements, which separate the SQL logic from user-supplied data and make injection structurally impossible. Additionally, CSRF tokens should be added to all login forms, and account lockout should be enforced after five failed login attempts to limit brute-force exposure.

```
// SECURE PHP EXAMPLE — parameterised query
$stmt = $pdo->prepare('SELECT * FROM users WHERE username = ? AND password = ?');
$stmt->execute([$username, $password]);
```

- Replace all direct SQL string concatenation with parameterised queries or prepared statements
- Consider using an ORM to abstract database interactions entirely
- Deploy a Web Application Firewall (WAF) to detect and block SQL injection patterns in real time
- Add CSRF tokens to all login and sensitive forms
- Enforce account lockout after 5 consecutive failed login attempts

F2 — Database Backup Exposure (Critical)

A database backup must never be stored inside a web-accessible directory. The file should be moved immediately to a location outside the web root, such as /var/backups/, which cannot be reached via HTTP. Going forward, all backups should be encrypted at rest, access-controlled by IP or user account, and stored off-site or on a dedicated backup server. A formal backup policy should be documented and enforced.

- IMMEDIATE: Remove mediroza_db_backup_2019.sql from the /old/ web directory
- Store all database backups outside the web root — a path like /var/backups/ is not reachable via browser
- Encrypt all backups at rest using AES-256 or equivalent
- Restrict backup access by IP whitelist and require authentication to retrieve
- Audit all remaining files in /old/, /staff/ and /patient/ directories and remove anything not actively needed
- Assess POPIA (Protection of Personal Information Act) breach notification obligations for the 30 affected staff members

F3 — Directory Indexing (High)

Directory indexing should be disabled globally on the LiteSpeed web server so that browsing to any folder without an index file returns a 403 Forbidden response rather than a file listing. An .htaccess rule should also be added to all sensitive directories as a secondary control.

- Disable directory indexing in LiteSpeed server configuration globally


```
# LiteSpeed / Apache — add to .htaccess in all sensitive directories
Options -Indexes
```
- Confirm the change is applied to /patient/, /staff/, /old/ and all other application directories

F4 — Weak PDF Encryption Passwords (High)

The passwords used to protect patient lab reports were trivially weak and appeared in the rockyou.txt wordlist. A strong password policy must be enforced for all document encryption. Passwords should be generated randomly per document rather than chosen manually, and the encryption standard should be upgraded from 128-bit RC4 to AES-256 as supported in PDF 2.0.

- Enforce a minimum 12-character password for all encrypted documents, combining uppercase,

lowercase, numbers and symbols

- Generate unique random passwords per patient report rather than using predictable or reused values
- Upgrade document encryption from PDF Standard V2.3 (128-bit RC4) to PDF 2.0 (AES-256)
- Consider using a secure password manager or document management system to handle password distribution to patients

F5 — Exposed Server Control Panel (High)

The web server control panel at /securecontrolpanel/ is publicly discoverable. Access to this interface should be restricted by IP whitelist so that it is only reachable from known administrator IP addresses. Multi-factor authentication should also be enforced on the control panel login.

- Restrict /securecontrolpanel/ to known administrator IP addresses via server or firewall rules
- Enforce multi-factor authentication on control panel access
- Consider relocating the panel to a non-default URL to reduce automated discovery risk

F6 — IlohaMail XSS (Medium)

IlohaMail 0.8.10 contains a known cross-site scripting vulnerability. The software should be upgraded to the latest patched version. If no patch is available, the webmail component should be replaced with a maintained alternative. A Content-Security-Policy header will also limit the impact of any XSS.

- Upgrade IlohaMail to the latest available version or replace with a maintained webmail solution
- Implement a Content-Security-Policy header to restrict script execution sources

F7 — Missing Security Headers (Medium)

Five HTTP security headers are absent from all server responses. These should be added to the LiteSpeed server configuration and applied globally. Each header addresses a specific class of attack.

```
Content-Security-Policy: default-src 'self'  
Strict-Transport-Security: max-age=31536000; includeSubDomains  
Referrer-Policy: strict-origin-when-cross-origin  
Permissions-Policy: geolocation=(), microphone=()  
X-Content-Type-Options: nosniff
```

- Add all five headers to the LiteSpeed server configuration and verify they appear in all responses
- Use a tool such as securityheaders.com to confirm correct implementation after deployment

F8 — robots.txt Information Disclosure (Low)

The robots.txt file listed all three sensitive directories by name. While robots.txt alone is not exploitable, it actively guided the reconnaissance phase of this assessment. Sensitive paths should be protected by proper access controls, not hidden from search engines via robots.txt.

- Remove sensitive directory paths (/patient/, /staff/, /old/) from robots.txt
- Rely on proper authentication and access controls to protect sensitive content, not robots.txt exclusions

□

CONCLUSION

The penetration test of Mediroza General Hospital identified a combination of critical vulnerabilities that, when taken together, represent a severe and ongoing risk to the organisation. Patient confidentiality has been compromised, staff personal data is publicly exposed, and corporate financial information is accessible to anyone with an internet connection. Immediate remediation of the two critical findings is strongly advised, followed by the high and medium findings in the weeks that follow.

A retest should be conducted after remediation to verify that all vulnerabilities have been effectively addressed and that no new issues have been introduced during the fix process.

Report prepared by: Blessing Princess Augustine | NetworkWalks Academy — Batch B083 | 01
October 2026

CONFIDENTIAL — AUTHORISED PERSONNEL ONLY